

@FEUP-ASSO-2025-26 C02-T3

Architectural Fitness Function

Legality of Open Source Libraries

01

*C*ontext & Problem

The Hidden Risk of Open-Source Dependencies

Viral Licenses

Open-source frameworks can carry licenses that legally force proprietary code to become open-source (e.g. GPL, AGPL, MPL)

The “Silent Shift”

Frameworks like Redis, Terraform, and Elasticsearch have shifted from permissive to restrictive licenses.

The Bottleneck

Manual legal reviews are slow and risky. We might miss a license change between cycles, leading to legal violations.

Question: What happens if one of the frameworks changes their license?

02

 **Quality Attributes**

Core Quality Attributes

Legal Compliance

Guarantee that no direct or transitive dependency exposes the company to legal liability.

Automated tool to block any dangerous licenses, like the GPL, before they can ever enter the codebase.

Maintainability

Prevent volatile technical debt.

Catching a bad license at an early stage to avoid having to rewrite the entire application in an emergency later on.

Auditability

Create a reliable, historically accurate audit trail.

Automatically tracks a history of every single check, giving legal teams a clear baseline registry to prove that the software has always followed the rules.

The Goal: Establish Automated, Continuous Detection

03

Fitness Function Solution

Fitness Function Dimensions

Scope

ATOMIC

Evaluates individual library metadata in isolation. Legal risk is per-dependency; a system-wide runtime view is unnecessary.

Cadence

TRIGGERED

Runs on-demand during manifest changes (e.g., package.json updates) or via scheduled "cron" scans for upstream changes.

Execution

AUTOMATED

100% automated detection/failure. Manual effort is reserved only for remediation (Legal/Architect review of flags).

Analysis

STATIC

Analyzes "contracts at rest" (manifests). The legal risk exists by simply including the package, regardless of execution.

Fitness Function Implementation



```
1  # CI step: run after dependency install
2  ALLOWLIST = load_json('.license-allowlist.json')
3  deps      = extract_all_licenses('package-lock.json')
4
5  baseline = load_json('.license-baseline.json') # committed snapshot
6  violations, regressions = [], []
7
8  for pkg, spdx in deps:
9      if spdx not in ALLOWLIST:
10         violations.append((pkg, spdx))
11     elif baseline.get(pkg) != spdx:          # license changed
12         regressions.append((pkg, baseline[pkg], spdx))
13
14  if violations:
15      report(violations)
16      exit(1)                                # fail the pipeline
17
18  if regressions:
19      report(regressions)
20
21  save_json(deps, '.license-baseline.json')  # update baseline on success
```

04

*C*onclusion

Conclusion

Legal compliance **cannot** be treated as a one-time, manual checkpoint.

By treating licenses as **code-level dependencies**, we catch legal risks early in development, before they become expensive problems.

Our fitness function acts as an **automated legal guardrail**, ensuring we can build fast without exposing the business to IP risks.

